



TRIỂN KHAI VÀ BÀN GIAO

Touch VN - Hướng dẫn cài đặt, triển khai và vận hành

Quy trình từ cài dependency, cấu hình môi trường đến phát hành, backup và rollback.

THÔNG TIN	NỘI DUNG
Đối tượng	Người triển khai, quản trị hệ thống và người nhận bàn giao
Phiên bản	Touch VN 1.1.0
Runtime	Python 3.11+; Flask/Waitress và FastAPI/Uvicorn
Nguyên tắc	Secret ngoài mã nguồn; HTTPS; không seed demo production

Phạm vi: Tài liệu thuộc bộ hồ sơ tốt nghiệp Touch VN - sinh viên Nguyễn Phạm Tân, MSSV 24730064, phiên bản sản phẩm 1.1.0.

1. Thành phần bàn giao

Thành phần	Mục đích	Trạng thái
Mã nguồn	Web, API, shared services, tests và scripts.	Có trong ZIP release
requirements.lock	Cài đặt dependency có hash.	Bắt buộc
sbom.cdx.json	Danh mục thành phần phần mềm.	Bắt buộc
.env.example	Mẫu cấu hình không chứa secret thật.	Bắt buộc
Tài liệu	Khóa luận, hướng dẫn, kiểm thử và demo.	Có trong hồ sơ
Runtime data	Database, log, cache, .venv.	Không đóng gói

2. Yêu cầu môi trường

- Windows 10/11 hoặc máy chủ hỗ trợ Python 3.11 trở lên.
- PowerShell để chạy script mẫu; quyền tạo thư mục ứng dụng và log.
- Reverse proxy và chứng thư TLS hợp lệ khi triển khai production.
- Kết nối mạng cho provider AI, vé, thời tiết hoặc nearby nếu bật tích hợp thật.
- PostgreSQL/Redis được khuyến nghị khi chạy nhiều instance; bản đồ án mặc định dùng SQLite.

3. Cài đặt tái lập

```
python -m venv .venv
.\venv\Scripts\python.exe -m pip install --require-hashes -r requirements.lock
Copy-Item .env.example .env
```

Không dùng requirements.txt không hash cho bản production nếu mục tiêu là cài đặt tái lập. Sau khi cài, lưu log cài đặt và chạy quality gate trước khi khởi động.

4. Cấu hình môi trường

Nhóm	Biến chính	Yêu cầu production
Ứng dụng	APP_ENV, APP_VERSION, APP_PUBLIC_BASE_URL	production; URL HTTPS thật.
Secret	APP_SECRET_KEY	Giá trị mạnh từ secret manager, không dùng mẫu.
Web	APP_DEBUG, ENFORCE_HTTPS, ENABLE_API_DOCS	false, true, false.
Demo	SEED_DEMO_USERS, DEMO_ADMIN_*	false và để trống.
Session	SESSION_IDLE_TIMEOUT_SECONDS, SESSION_ABSOLUTE_TIMEOUT_SECONDS	Theo chính sách tổ chức.
JWT	AUTH_TOKEN_TTL_SECONDS, AUTH_TOKEN_AUDIENCE	Audience riêng và TTL hữu hạn.
Proxy/CORS	TRUSTED_PROXY_IPS, CORS_ALLOWED_ORIGINS	Chỉ khai báo đích tin cậy.
Provider	OPENAI_* và EXTERNAL_*	Cấp qua secret manager; kiểm tra health.
Giới hạn	MAX_IMAGE_PIXELS, SECURITY_ALERT_*	Không nói quá mức khi chưa đánh giá.

```
APP_ENV=production APP_SECRET_KEY=<secret-manh> APP_DEBUG=false ENFORCE_HTTPS=true
ENABLE_API_DOCS=false SEED_DEMO_USERS=false APP_PUBLIC_BASE_URL=https://your-domain.example
```

5. Chạy local

```
.\.venv\Scripts\python.exe run_web.py \.venv\Scripts\python.exe run_api.py Web: http://127.0.0.1:5000/ API docs
development: http://127.0.0.1:8000/docs
```

Tài khoản demo: Chỉ cấu hình qua .env local với APP_ENV=development và SEED_DEMO_USERS=true. Không đưa email/mật khẩu demo vào source, README, database hoặc ZIP production.

6. Kiến trúc production đề xuất

- Reverse proxy nhận HTTPS, áp giới hạn request và chuyển tiếp đến web/API.
- Waitress phục vụ Flask web; Uvicorn phục vụ FastAPI.
- PostgreSQL/PostGIS lưu dữ liệu; Redis lưu session/rate-limit state nếu nhiều instance.
- Secret manager cấp APP_SECRET_KEY và API key tại runtime.
- Log ứng dụng/audit chuyển về hệ thống tập trung và cảnh báo theo ngưỡng.
- Backup database, kiểm tra restore và giám sát health endpoint.

7. Quality gate trước triển khai

```
.\scripts\run_quality_checks.ps1 .\scripts\run_quality_checks.ps1 -IncludeDynamicSecurity
```

- 20/20 acceptance tests đạt.
- Python compile và JavaScript syntax đạt.
- SAST, lockfile/SBOM verification và dependency scan không còn lỗi chặn.
- DAST và stress smoke đạt trong môi trường gần production.
- Secret, demo account, .env, database, log và cache không nằm trong gói.

8. Database, backup và restore

Bản đồ án dùng data/travel_app.db. Trước backup cần dừng thao tác ghi hoặc dùng cơ chế backup nhất quán. Lưu database, cấu hình không bí mật, phiên bản code và checksum cùng một mốc thời gian. Không lưu APP_SECRET_KEY trong file backup tài liệu.

Tình huống	Thao tác	Kiểm tra sau cùng
Backup định kỳ	Sao lưu database và manifest phiên bản.	Mở bản sao, kiểm tra schema và số bảng.
Restore	Dừng app, khôi phục database, chạy migration/init an toàn.	Health, login, places, planner và dashboard.
Chuyển phiên bản	Backup trước; triển khai code + dependency mới.	Chạy smoke và kiểm tra log/audit.
Rollback	Khôi phục code, lockfile và database tương thích.	Xác minh health, auth và dữ liệu người dùng.

9. Log, giám sát và cảnh báo

- Theo dõi tỉ lệ HTTP 5xx, p95 latency, timeout provider và lỗi database.
- Cảnh báo đăng nhập thất bại, từ chối quyền, thao tác admin bất thường và lỗi tích hợp.
- Xác minh HMAC audit log; phân quyền đọc log và đặt retention phù hợp.
- Không ghi password, token, API key hoặc nội dung nhạy cảm vào log.
- Xoay vòng log; bảo đảm ổ đĩa không đầy và thời gian hệ thống chính xác.

10. Cập nhật và rollback

- Tạo nhánh/bản release và ghi rõ version.
- Chạy quality gate đầy đủ trên artifact sắp triển khai.
- Backup dữ liệu và lưu checksum của bản đang chạy.
- Triển khai canary hoặc thời gian ít tải nếu có thể.
- Kiểm tra health, đăng nhập, điểm đến, planner, booking, dashboard và log.
- Nếu vượt ngưỡng lỗi, rollback code + dependency + schema tương thích.

11. Checklist bàn giao

Hạng mục	Tiêu chí	Xác nhận
Mã nguồn/ZIP	Có checksum; mở được; không có secret/runtime data.	☐
Khóa luận/slide	Đúng phiên bản, tên sinh viên và MSSV.	☐
Cấu hình	.env.example đầy đủ; secret được chuyển qua kênh riêng.	☐
Tài khoản	Demo chỉ local; production có quy trình tạo admin.	☐
Database	Có backup/restore test và người chịu trách nhiệm.	☐
Provider	Endpoint/key/owner/quota/timeout được ghi nhận.	☐
Quality gate	Có báo cáo ngày chạy và kết luận.	☐
Vận hành	Có log, alert, backup, rollback và liên hệ sự cố.	☐